

단말 보안지침



주식회사 모인

개정 이력

[illegible]

단말기 보안지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 “회사”라 한다)의 단말기 사용에 관한 사항을 규정하는 정책시행 문서로서 단말기 보안 요구사항을 준수하기 위한 기준으로써 활용함을 그 목적으로 한다.

제2조(적용 범위) 이 지침은 모든 사용자와 단말기를 대상으로 한다.

제3조(용어의 정의) 이 지침은 다음 용어 정의를 따른다.

- 1 “단말기”란 일반 PC 환경에 부가적으로 각종 업무용 S/W를 설치하여 사용할 수 있도록 구성된 데스크탑 PC, 노트북 등을 의미한다.
- 2 “중요단말기”란 데이터센터 내에 위치한 정보처리시스템의 운영 및 보안 목적으로 직접 접속하는 단말기로 외부 반출, 인터넷접속, 그룹웨어의 접속 금지 등 강화된 보호대책이 적용된 단말기를 의미한다.
- 3 “보조저장매체”란 이동형 하드디스크, USB메모리, CD(Compact Disk), DVD(Digital Versatile Disk) 등 자료를 저장할 수 있는 매체로서 정보처리시스템 또는 단말기 등과 용이하게 연결·분리할 수 있는 저장매체를 의미한다.
- 4 “사용자”란 회사 업무를 수행하기 위하여 단말기를 이용하는 임직원 및 외주직원 모두를 의미한다.

제2장 역할 및 책임

제4조(정보보호최고책임자)

- 1 정보보호최고책임자(이하 “CISO”라 한다)는 단말보안 관리 업무에 대한 총괄 책임을 가진다.
- 2 CISO는 정보보호 담당자의 단말보안 관리 업무 수행에 대한 활동내역을 검토하여야 하며, 해당 업무에 대하여 집행할 책임이 있다.
- 3 CISO는 주기적으로 사용자의 이 지침 준수 여부를 평가하고, 부적절한 사항에 대하여 개선하도록 요구할 책임과 권한을 가진다.

제5조(정보보호 담당자)

- 1 정보보호 담당자는 단말보안 관리에 대한 활동을 수행하고, 그 결과를 CISO에게 보고하여야 한다.
- 2 사용자에게 기본적인 보안설정이 적용된 단말기를 지급하여야 할 책임을 갖는다.

3 단말기 및 보조저장매체의 보안 준수사항 등을 사용자에게 명확히 공지하여야 한다.

제6조(사용자)

- 1 사용자는 개인에게 부여된 단말기의 사용부터 반납 시까지 단말기 운영에 대한 책임을 가지고 있으며, 이 지침에서 요구하는 단말기의 보안설정 및 관리, 상용 소프트웨어의 설치 및 폐기 방침을 준수할 책임이 있다.
- 2 사용자가 이 지침에 규정한 사항을 준수하지 않음으로써 발생하는 회사의 모든 손실에 대하여 본인에게 책임이 있음을 인지하여야 한다.

제3장 단말보안 준수사항

제7조(단말기 보호대책)

- 1 정보보호 담당자는 사용자에게 단말기를 지급하기 전 다음 각 호의 보안프로그램을 직접 설치하거나, 정상적으로 설치가 될 수 있도록 지원하여야 한다.
 - 1) 악성코드 검색 및 치료 프로그램
 - 2) 패치관리시스템(PMS)
 - 3) 데이터유출방지솔루션(DLP)
 - 4) 네트워크접근통제솔루션(NAC)
 - 5) 그 외 필수적인 보안시스템
- 2 정보보안팀(이하 “보안팀”)은 단말기의 관리 강화와 분실, 도난 등에 대비하여 단말기 내 하드디스크 암호화를 적용할 수 있다.
- 3 망분리 적용 예외에 따라 사용되는 단말기는 다음 각 호의 보안 설정을 적용하여야 한다.
 - 1) PC 사용자의 관리자 권한 제거
 - 2) 승인된 프로그램만 설치 또는 실행
 - 3) 단말기 내 하드디스크 암호화 또는 데이터 암호화 저장
- 4 인가된 사용자에게 의한 단말기 사용

제8조(비밀번호 생성 및 관리)

- 1 사용자는 다음 각 호의 사항에 따라 단말기의 비밀번호를 설정하여야 하며, 정보보호 담당자는 이를 준수할 수 있도록 기술적으로 가능한 범위 내에서 보안 정책을 설정하여야 한다.
 - 1) 영문 대/소문자, 숫자, 특수문자 중 두 가지 혼합 시 10자 이상, 세 가지 혼합 시 8자 이상 문자열로 패스워드 설정
 - 2) 계정ID, 생년월일, 주민등록번호, 전화번호 등 유추하기 쉬운 비밀번호 사용 금지
 - 3) 계정 잠금 임계 값 5회 이하

- 4) 비밀번호 최대사용기간 90일 이하
- 2 초기 비밀번호는 사용자 로그인 이후에 바로 변경하는 것을 원칙으로 한다.
- 3 사용자는 비밀번호를 메모 또는 문서의 형태로 보관하지 않도록 하여야 한다.
- 4 사용자는 비밀번호를 타인에게 공유 또는 의도적 유출을 하지 않으며, 이에 대한 책임은 사용자에게 있다.
- 5 사용자로부터 비밀번호의 초기화(reset) 등 인증 관련 변경요청이 있는 경우, 정보보호 담당자는 사용자 본인의 요청에 의한 것인지를 콜백 등의 방법으로 먼저 확인해야 한다.

제9조(화면보호기 설정)

- 1 회사는 업무담당자 본인 외에는 단말기를 조작할 수 없도록 단말기에 화면보호기 설정을 강제화 하여 비인가자의 단말기 접근을 방지하여야 한다.
- 2 화면보호기는 15분 이내로 작동하도록 설정하고, 재사용 시 비밀번호로 보호되어야 한다.
- 3 사용자는 자리를 비우기 전에 화면보호기를 작동하여야 한다.

제10조(공유 폴더 및 파일 공유) 공유 폴더 사용은 원칙적으로 금지하며, 업무상 공유 폴더의 사용이 불가피한 경우 보안팀의 승인 하에 다음 각 호에 따라 관리하여 사용하여야 한다.

- 1 인가된 사용자만 공유폴더에 접근할 수 있도록 사용자 별 폴더 접속 권한을 부여한 후 사용하여야 한다.
- 2 폴더 공유자는 공유목적 달성 시 즉시 공유설정을 해제하여야 한다.
- 3 공유 폴더 접근을 위한 별도의 계정을 생성하는 경우, 해당 계정이 공용으로 사용되어서는 아니 되며, 제8조에 따라 비밀번호를 설정하여야 한다.

제11조(중요정보 저장 통제)

- 1 단말기 및 보조저장매체에는 개인정보 등 중요정보를 저장하지 않는 것을 원칙으로 한다.
- 2 사용자는 제1항에도 불구하고 불가피하게 중요정보를 저장할 필요가 있는 경우, 보관사유, 보관기간 및 상용 암호화 소프트웨어 또는 안전한 알고리즘으로 암호화하고, 보안팀의 승인을 득하여야 한다.

제12조(보조저장매체 통제)

- 1 내부 임직원의 보조저장매체 사용은 읽기만 허용하고 원칙적으로 쓰기(write)를 금지한다.
- 2 불가피하게 보조저장매체에 파일을 저장하여야 하는 경우, 다음 각 호를 준수하여야 한다.
 - 1) 개인정보가 미 포함된 파일 저장 시 보안팀의 승인을 득한다.
 - 2) 개인정보가 포함된 파일의 경우 상용 암호화 소프트웨어 또는 안전한 알고리즘을 사용하여 암호화하여 저장하고, 보안팀의 승인을 득한다.
- 3 보조저장매체 사용 시에는 바이러스, 악성코드가 유포되지 않도록 다음 각 호의 보안 대책을 적용하여야 한다.

- 1) 자동실행 기능 차단
- 2) 단말기 연결 후 바이러스 및 악성코드 자동 검사
- 3) 보조저장매체의 쓰기 권한 부여 시 사용 기간 설정
- 4 보조저장매체의 보관은 시건 장치가 되어있는 서랍에 안전하게 보관하여야 하며, 정보보호 담당자는 보조저장매체 보유 및 관리 현황을 주기적으로 점검하여야 한다.
- 5 외부직원의 보조저장매체 사용은 원칙적으로 읽기, 쓰기 모두 차단한다.

제13조(악성코드 감염방지)

- 1 회사는 다음 각 호에 따라 단말기에 악성코드 검색 및 치료 프로그램(이하 '백신' 이라 한다)을 설치·운용한다.
 - 1) 백신은 자동으로 실행되도록 하고, 정기적으로 업데이트를 수행하여 최신상태를 유지하여야 한다.
 - 2) 백신의 업데이트와 검사 주기 설정은 관리자에 의해 수행되고, 사용자에 의해 임의로 중단될 수 없도록 한다.
 - 3) 백신의 로그는 최소한 1년간 보존되도록 충분한 로그용량을 설정해야 한다.
 - 4) 응용프로그램을 사용할 때에는 백신 진단 및 치료 후 사용한다.
 - 5) 인터넷에서 획득한 파일, 기타 외부로부터 획득한 파일 등에 대하여 악성코드 감염 여부를 즉시 점검하도록 설정해야 한다.
- 2 악성코드 감염이 발견된 경우, 악성코드 확산 및 피해를 최소화하기 위하여 다음 각 호에 따라 감염의 확산을 방지한다.
 - 1) 누구든지 악성코드 감염을 발견하면 단말기 사용을 중지하고, 네트워크로부터 분리하여 해당 단말기를 격리시키고, 설치된 백신을 사용하여 치료한다.
 - 2) 백신으로 악성코드가 제거되지 않을 경우, 즉시 보안팀에 알린다.
 - 3) 보안팀은 감염 원인과 경로 등에 대한 조사가 끝난 후, 컴퓨터 초기화 등 적절한 조치를 취한다.
 - 4) 보안팀은 재발 방지를 위해 악성소프트웨어의 감염 원인과 경로, 대응방법 등에 대한 정보를 사용자에게 공지한다.
 - 5) 그 외 세부적인 대응 및 복구 사항은 「침해사고 대응 매뉴얼」에 따른다.

제14조(비인가 소프트웨어 통제) 회사는 단말기에 업무목적과 관계없는 다음 각 호의 비인가 소프트웨어 설치 및 사용을 통제하여야 한다.

- 1 라이선스가 없는 정품 소프트웨어
- 2 인터넷을 통한 불법 복제 소프트웨어
- 3 그 외 허가되지 않은 비인가 소프트웨어

제15조(인터넷 접속통제)

- 1 회사는 정상적인 경영 활동을 위하여 인터넷 상의 특정 사이트에 대한 접속 및 사용을 금지할 수 있으며, 접속 및 사용 금지 대상은 다음 각 호와 같다.
 - 1) 유해 사이트
 - 2) 정보 유출이 우려되는 사이트
 - 3) 그 외 보안정책 상 금지되는 사이트
- 2 회사는 사용자의 인터넷 접속에 대해 접속일시, 출발지 및 목적지 IP, 접속포트(Port), 사설IP 주소 등이 포함된 내역을 기록하여 1년 이상 보관하여야 한다.
- 3 외부직원의 무선네트워크 사용은 원칙적으로 금지한다.

제16조(전자메일 보안)

- 1 사용자는 개인(신용)정보를 전자메일을 활용하여 외부에 전달하는 경우에는 문서 암호 또는 압축파일 암호를 설정하여 책임자의 승인을 득한 후 전송한다.
- 2 사용자는 발신인이 불확실하거나, 첨부파일 등이 의심스러운 전자우편은 열람하지 말고 즉시 삭제하여야 한다.
- 3 보안팀은 전자메일을 이용한 정보 유출 등을 방지하기 위하여 첨부파일 용량 등을 제한할 수 있다.

제17조(중요단말기 지정 및 관리)

- 1 CISO는 다음 각 호의 중요단말기를 지정하고, 기기정보와 중요단말기 사용자 현황을 지속적으로 관리하여야 한다.
 - 1) 정보처리시스템 또는 중요 DB에 직접 접근이 가능한 권한이 부여된 단말기
 - 2) 그 외 CISO가 필요하다고 인정하는 단말기
- 2 제1항에 따라 지정된 중요단말기는 다음 각 호의 사항을 준수하여야 한다.
 - 1) 외부 반출금지
 - 2) 사전 지정용도 외 사용 금지
 - 3) 노트북 등 휴대용 전산장비 사용 금지
 - 4) 인터넷 및 그룹웨어 접속 금지
 - 5) 악성코드 매일 점검 실시

제18조(원격접속 단말기 통제)

- 1 외부에서 인터넷을 통해 내부 네트워크에 접근 시 사용되는 원격접속 단말기는 보안팀에서 제공한 개인 방화벽 소프트웨어를 설치하고, 다음 각 호와 같이 구성하여야 한다.
 - 1) 개인 방화벽 소프트웨어는 항상 활성화 상태로 실행되도록 구성
 - 2) 개인 방화벽 소프트웨어는 사용자가 변경할 수 없도록 구성
- 2 사용자가 회사 네트워크에 원격접속 시도 중 개인 방화벽 소프트웨어가 활성화되지 않은 경우

원격접속을 허용하지 않을 수 있다.

- 3 원격접속 단말기의 하드디스크 및 보조저장매체 등을 통한 데이터의 이동·복사·저장을 금지하며, 업무상 필요한 경우 정보보호 담당자의 사전 승인을 받아야 한다.

제19조(모바일 기기 통제)

- 1 회사는 사용자가 업무용으로 모바일 기기를 활용하는 경우, 분실, 도난 등으로 인한 중요정보의 유·노출을 방지하기 위하여 다음 각 호의 보안대책을 적용할 수 있다.
 - 1) 비밀번호, 패턴, PIN, 지문, 홍채 등을 사용하여 화면 잠금 설정
 - 2) 디바이스 암호화 기능 등을 사용하여 애플리케이션, 데이터 등 암호화
 - 3) 모바일 기기 제조사 또는 이동통신사에서 제공하는 기능을 이용한 원격잠금, 원격 데이터 삭제(킬 스위치 서비스 등)
 - 4) 개인정보를 처리하는 모바일 기기의 경우 모바일 단말 관리 프로그램(MDM)을 설치하여 원격 잠금, 원격 데이터 삭제, 접속통제
- 2 모바일 기기 내 데이터 및 문서 저장은 원칙적으로 금지한다.

제20조(유지보수)

- 1 단말기의 유지보수는 인가된 직원에 의해서만 수행하여야 하며, 유지보수 직원에 의해 수행될 경우 사용자 또는 보안팀의 참석 하에 유지보수가 이루어지는 것을 원칙으로 한다.
- 2 유지보수 직원이 단말기 수리로 인하여 이동·반출할 경우 단말기에 저장된 정보의 중요도에 따라 복구가 불가능하도록 완전 삭제 프로그램을 사용한 후 반출하여야 한다.

제21조(반출입 통제)

- 1 중요 단말기와 업무용 모바일 기기는 원칙적으로 반출을 금지하며, 업무 목적으로 반출입이 필요한 경우 다음 각 호의 사항을 기록하여 보안팀의 승인을 거쳐야 한다.
 - 1) 반출입자 정보
 - 2) 반출입 기기 정보(자산번호, 반출사유, 반출입자, 반출(예정)시각, 반입일시 등)
 - 3) 신청일시
 - 4) 승인일시
 - 5) 승인자 정보
 - 6) 보안점검 확인 결과 등
- 2 보안팀은 제1항 제6호와 관련하여 반출입 목적의 타당성과 다음 각 호의 보안준수사항을 검토하여 결과를 기록하여야 한다. 다만, 제20조 제2항에 따른 반출 시 보안준수사항 검토는 생략할 수 있다.
 - 1) 백신 설치 및 최신 업데이트 여부
 - 2) 악성코드 감염 여부

- 3) 필수 보안 S/W 설치 및 정상작동 여부
- 4) 그 외 필요하다고 판단이 되는 사항

제22조(서비스 팩 및 패치 설치) 단말기 운영체제 및 설치된 소프트웨어의 패치와 관련한 사항은 「정보시스템 보안 지침」 제10조에서 정한 바를 따른다.

제23조(이전 및 용도 변경)

- 1 사용자는 타 부서로 이전 시 기존 단말기를 연속해서 사용한다. 다만, 중요단말기를 보유하고 있는 경우, 이전하는 부서의 업무 분장에 따라 불필요 시 보안팀에 반납하여야 한다.
- 2 회사는 사용자의 단말기에 대해 용도 변경이 필요한 경우에는 저장하고 있는 모든 정보를 삭제하여 초기화 하고, 제7조에 따라 보호대책을 적용한 후 사용하여야 한다.

제24조(폐기) 단말기 폐기와 관련한 사항은 「정보시스템 보안 지침」 제12조에서 정한 바를 따른다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.